Leonard Sambu

Security Researcher | Smart Contract Auditor | AI Agent Engineer | Fullstack Developer

+254 739 720 531 cheruiyootsambu@gmail.com /in/cheruiyoot-sambu
github.com/llakterian llakterian.github.io

Professional Summary

Most of my work is finding bugs in code that holds other people's money, then writing the proof that stops anyone from waving them away.

Across roughly 60 bug bounty programs on HackenProof, Cantina, Bugcrowd, Intigriti and Immunefi — 20 of them smart contract audits — the findings I am proudest of are arithmetic ones. An underflow in Frax's sfrxETH withdrawal path, where a cached `totalAssets` drifts against the live figure and strands LP redemptions. A payout path in tokenize.it where a caller-supplied base price lets a coininvestor walk off with an entire exit. Both ship as runnable Foundry proof-of-concepts, the sfrxETH one against a live mainnet fork. I run the audits with AI agents in parallel lanes and then verify every claim myself.

A large share of that work ends with me not filing. Three of my own reports were closed by triagers, two of them as intended behaviour, so I work to a written gate that stops me filing anything a privileged role could reach, and I built the tooling around it: `c0bw3b`, a 13,000-line Python pipeline with 31 modules and 107 passing tests, MIT licensed and installed as a CLI.

I build as much as I break. C. Sambu Farm Manager replaced the physical payroll workbook of a tea estate running 20–30 pluckers and 12–39 tonnes of green leaf a month, and now prices piece-rate, day-rate and prorated pay in one engine. Maziwa Coop (maziwa-coop.pages.dev) sends dairy farmers their delivery confirmation by SMS and generates the month-end statements they used to write by hand. The CRUD was never the hard part — the domain was: a feed-ration solver built on KALRO nutrient tables, tea factory rates that change by effective date, and dates that stay correct in EAT. I also take paid incident response and forensics on WordPress estates, and build lead pipelines on Cloudflare.

I run teams across media, education and tech, so I can sit with a farmer over their deduction statement and with an auditor who thinks their finding will not pay.

Technical Skills

Security & Auditing	Smart contract auditing, vulnerability research, penetration testing, threat modeling, code review, responsible disclosure, OWASP Top 10, digital forensics
Blockchain	Solidity, Foundry, Hardhat, Slither, Mythril, Echidna, EVM internals, proxy patterns (UUPS/-Transparent), ERC-4626, cross-chain bridge security, IPFS
Languages	JavaScript, TypeScript, Solidity, Python, Bash
Fullstack	React.js, Next.js, Node.js, Express.js, Hono.js, RESTful APIs, Web3.js, Ethers.js, Zustand, Recharts, Tailwind CSS
AI & LLMs	Claude API, Groq API, Gemini, MCP, Agentic AI Orchestration, Prompt Engineering, Deepseek, NVIDIA
DevOps & Tools	Git, Docker, Foundry, JIRA, Trello, CI/CD, Cloudflare Workers, Cloudflare Pages, Netlify, Wrangler CLI
Other	Linux, Windows, macOS, DaVinci Resolve, OBS Studio, Google Workspace, Microsoft Office

Independent Security Research

Security Researcher & Bug Bounty Hunter *Independent*
2024 to Present

- Audited 20 smart contract codebases (Frax, Paxos, USDai, Cetus, Revert, Alberich, Zendex, DreamX) and worked 40+ web2 programs on HackenProof, Cantina, Bugcrowd, Intigriti and Immunefi.
- Reported an arithmetic underflow in Frax's sfrxETH withdrawal path, where a cached `totalAssets` drifts against accrued rewards and strands LP redemptions, and a caller-supplied base price in tokenize.it's exit payout that let a coininvestor take 100% of the exit proceeds; both shipped as runnable Foundry proof-of-concepts, the first verified against a live mainnet fork.
- Found a critical blind stored XSS that executed inside an internal backoffice application and exposed national ID numbers and phone numbers, and an IDOR in a B2B platform that was triaged and rewarded.
- Built the verification to match: Foundry, Hardhat and Sui test suites, mainnet forks, gas measurement and on-chain state reads, plus a standing filing gate that keeps privileged-role findings out of the queue before a judge sees them.
- Ran the audits with AI agents in parallel lanes across governance, ledger and write-path surfaces, then confirmed every claim by hand and wrote triage-ready reports with severity classification, root cause analysis, remediation steps, and the dismissal vectors already considered.

Projects & Portfolio

Note: For an exhaustive list of all tools, agents, and applications I have built, please visit my interactive portfolio at llakterian.github.io.

Maziwa Coop: Milk Cooperative Management System *maziwa-coop.pages.dev*

Production-deployed platform for Kenyan dairy cooperatives, replacing paper delivery records with daily milk logging, auto-generated ticket numbering, Africa's Talking SMS confirmations sent to farmers, milking-can credit tracking and CSV reporting. The SMS provider sits behind an abstraction, so it can be swapped without touching the core. Tech: React 19, Hono.js on Cloudflare Workers, D1, Zustand, Recharts.

C. Sambu Farm Manager: Full-Stack Farm Management PWA *Live API*

PWA for a multi-sector Kenyan agribusiness (tea, dairy, avocado, poultry) that replaced a physical payroll workbook covering 20–30 pluckers and 12–39 tonnes of green leaf a month. A single payroll engine prices piece-rate (KES 9/kg), day-rate and prorated salary. Also a feed-ration solver built on KALRO nutrient tables, effective-dated tea factory rates, Open-Meteo weather across 14 Kenyan regions, and Workbox offline caching. Migrated from local IndexedDB/FastAPI/Docker to Cloudflare Workers + D1.

Shambani: AI Agronomy & Weather Advisory *shambani-app.pages.dev*

Weather intelligence for all 47 Kenyan counties: current conditions, 7-day forecast and AI agronomic advice grounded in KALRO, Tea Research Foundation of Kenya and Ministry of Agriculture extension guidelines, plus livestock feed profiling. Keys stay server-side behind a single proxy chokepoint, with a 5-minute cache that falls back to stale data on upstream failure. Tech: FastAPI + Cloudflare Pages Functions, Groq (gpt-oss-20b), Open-Meteo, vanilla-JS PWA.

QuitVaping: AI Cessation Platform *quitvaping.netlify.app*

Production Flutter web PWA for nicotine cessation: abstinence tracking, health-recovery timeline, savings calculator, an AI coach, craving-pattern analysis, guided panic-mode breathing, NRT tracking and community support, monetised through RevenueCat. Ships a full Model Context Protocol client stack and a Supabase backend with edge functions and web push. 36,000 lines of Dart across 117 files, backed by a Postman/Newman API test suite.

c0bw3b Toolkit: Automated Reconnaissance & Vulnerability Scanner

Custom automated scanning pipeline for Web2 bug bounty. 13,000 lines of Python across 31 decorator-registered modules: passive and active recon, JavaScript secret extraction, port scanning, historical URL collection, CORS/IDOR/SQLi/SSRF detection, false-positive verification and attack-chain correlation. 107 passing tests. MIT licensed, installs as a `c0bw3b` CLI.

CVEScan: CVE Monitoring & Web Scan Pipeline

Self-hosted eight-stage web scanner (tech fingerprinting, security headers, critical paths, directory brute force, JavaScript analysis, API discovery, injection testing, CORS/CSRF) that also monitors NVD, MITRE and GitHub Advisory feeds and emits LaTeX/PDF reports. 6,400 lines of TypeScript with a scheduler and webhook notifications.

Curated Feed: AI Content Curation Engine

Digital autonomy engine integrating Groq API (Llama 3.3 70B) for real-time curation with KV storage.

BotIn: Decentralized AI Agent Network

Decentralized AI agent professional network utilizing ERC-8004 for agentic identities and XMTP messaging.

FinPro: Decentralized Project & Finance Platform

Delivered to a client under a conditional source-available licence: escrow-based project payments, an ERC-20 token, a swap module, a multisig treasury, EIP-4337 gasless accounts with a token paymaster, and a Telegram Mini App. 7 audited Solidity contracts with 33 passing Hardhat tests and Playwright end-to-end coverage; Supabase with row-level security, Stripe checkout, and a TON sidechain data registry.

KinSync: Digital Estate Vault (Front-End Prototype)

Next-of-Kin digital estate vault prototype: wallet-linked vault dashboard, legacy record sync and emergency delegate status. React 19, Vite, wallet connection, mock data.

NimbusTrade: Web3 Arbitrage Dashboard

Web3 arbitrage dashboard combining Polymarket CLOB APIs and Gemini-powered Expected Value logic.

PicKut AI: AI Image Editing Suite

Professional image editing suite powered by Gemini 2.5 Flash Image, featuring ERC-8004 agentic Web3 payments.

SafeShamba: Notary-Mediated Escrow with Multisig Custody *safeshamba.us.ci*

Secure land purchase escrow platform with multisig custody and state-gated fund releases. Four-phase workflow: intake, safety gate (due diligence), execution/fiat bridge, transfer registry. Solidity 0.8.19 contracts (EscrowFactory, NotaryMediatedEscrow, MultiSigWallet) audited with Foundry (21 passing tests) and Slither; React 18 + ethers.js + Vite frontend deployed on Cloudflare Pages. MIT license with commercial agreement.

Uplift News: Multi-Language News Platform

Multi-language platform built with React, Cloudflare Workers, D1 database, and Groq AI for content curation.

Professional Experience

Project Manager *SIZLAND Limited*
Nov 2025 to Mar 2026

- Orchestrated Agile and Scrum workflows in a Web3 environment, optimizing task allocation and sprint delivery via JIRA and Trello.
- Delivered a 39,000-line content curation platform and a notary-mediated escrow system with smart contracts, front-end ABIs and handover documentation, invoiced against the consultancy agreement.
- Anticipated and mitigated project risks, conflicts, and cross-team dependencies through proactive strategies.
- Partnered with development and QA teams to rigorously validate deliverables, ensuring technical and functional excellence.
- Directed stand-ups, sprint reviews, and retrospectives; served as central liaison between developers, executives, and external partners.
- Championed comprehensive technical documentation and evolved best-practice SOPs to elevate operational standards.

Indie Game Developer (Charity Project) *Jampack Incubator*
Feb 2026

- Developed and launched Mathlantis, an educational web application combining math challenges with puzzle-building mechanics for Games for Love's mission.
- Honored with the "Most Child Friendly Game" title badge for accessible and engaging design.

Technology Consultant & Developer *Self-Employed*
Sep 2023 to Present

- Built and deployed production full-stack applications (Maziwa Coop, Sambu Farm Manager) on Cloudflare's serverless edge infrastructure with JWT auth, role-based access, and schema migrations applied live against production D1.
- Ran paid incident response and forensics on WordPress estates: recovered a client across four outage episodes, removed a PHP webshell and eight hidden administrator accounts, rotated salts, and cut TTFB from 30+ seconds to 1.1 seconds.
- Architected a production lead pipeline connecting Meta Lead Ads to a CRM through Cloudflare Workers and KV, including a Zapier bridge that works around Meta's App Review restriction on direct lead webhooks, with deduplication and a 90-day audit trail.
- Engineered and audited Solidity smart contracts using static analysis tools (Slither, Mythril); reduced exploit risk surface by 40%.
- Created blockchain security educational content on TikTok (@tech_ale).

Director and Manager *Sambu Academy*
Aug 2022 to Present

- Directed educator teams delivering high-impact operations and upholding elite service standards.
- Implemented streamlined SOPs that boosted overall productivity by 30%.

Previous Professional History

- **Technical Director and Editor** | KASS Media — Jul 2020 to Apr 2023
- **Firm Manager** | KASS Media (Ainoop Pkeles Studios) — Mar 2019 to Apr 2023
- **Manager: Logistics, Building and Construction** | KASS Media — Feb 2019 to Aug 2022
- **Passenger Handling Agent** | Swiss Port Kenya Ltd — Aug 2011 to Dec 2011
- **Public Relations Attaché** | KEMSA — 2011

Certifications & Training

Professional & Technical Certifications

- SkillQuest – Generative AI Literacy (SkillUP by Simplilearn) – 92%, 23/25, Cert. No. 44822733 — *2026*
- CompTIA Cloud+ (CV0-003) Specialization (Coursera) — *In Progress*
- Leveraging Virtual Assistants for Personal Productivity (Coursera Instructor Network) — *2024*
- Develop a Company Website with Wix (Coursera Project Network) — *2022*
- Full Stack Web3 Development Crash Course (Cyfrin Updraft)
- Solidity Smart Contract Development (Cyfrin Updraft)
- Smart Contract Security (Cyfrin Updraft)
- Cybersecurity Awareness and Innovation (EIT Digital / Coursera) — *2024*
- Digital Forensics Masterclass: Forensic Science DFMC+ (Udemy)

Security & Defense Training

- Insider Threat Awareness (DCSA / CDSE) — *2024*

- Establishing an Insider Threat Program for your Organization (DCSA / CDSE) *2024*
- Maximizing Organizational Trust (DCSA) *2024*

Personal Development

- Non-Technical Life Skills Course *2022*

Education

B.A. International Relations & Diplomacy with I.T.	Maseno University	2008 to Present
Certificate in HTML Web Language	Star College	2008
Kenya Certificate of Secondary Education	Milimani High School	2006 to 2007